

INTERNAL NETWORK AND WEB APPLICATION PENETRATION TEST



Executive Security Assessment Report — June 2026

Robes Fokoueng

CYBERSECURITY PROFESSIONAL | OFFENSIVE SECURITY ENTHUSIAST

INTERNAL LAB USE ONLY

NIST SP 800-115 | OWASP TOP 10 | MITRE ATT&CK | CVSS V3.1

DISCLAIMER AND CLASSIFICATION

INTERNAL LAB USE ONLY

⚠ PROFESSIONAL DEVELOPMENT NOTICE

This document is intended solely for **personal and professional development review**. All penetration testing activities documented herein were conducted within a **controlled, isolated home laboratory environment**. No real-world production systems, third-party networks, or external entities were targeted or impacted.



LAB ENVIRONMENT

Testing executed within a VirtualBox isolated subnet (192.168.1.0/24) with no external internet exposure.



AUTHORIZED SCOPE

All targets are intentionally vulnerable systems or VM instances owned and administered by the assessor.



ZERO IMPACT

Assessment protocols ensured no disruption to production traffic or external organizational assets.

TABLE OF CONTENTS

INTERNAL LAB USE ONLY

01 Executive Summary

02 Scope & Environment

03 Assessment Methodology

04 Attack Surface Overview

05 Infrastructure Security Findings

06 Web App Findings — Critical

07 Web App Findings — High & Medium

08 Cross-System Risk Analysis

09 Risk Summary Dashboard

10 Overall Business Impact

11 Strategic Recommendations

12 Conclusion

Overview of the presentation structure, covering executive summary, scope, methodology, detailed findings, chained attack scenarios, and strategic remediation recommendations.

EXECUTIVE SUMMARY AND RISK SCORECARD

INTERNAL LAB USE ONLY

OVERALL RISK POSTURE

HIGH

The assessment identified 9 validated security findings. Multiple critical vulnerabilities enable complete authentication bypass and unauthorized data exfiltration.

FINDING COUNT SUMMARY

SEVERITY LEVEL	COUNT	HIGHEST CVSS V3.1
● Critical	2	9.8
● High	6	8.6
● Medium	1	4.3
Total Findings	9	—

CRITICAL SECURITY THEMES



SQL Injection: Auth Bypass & DB Exfiltration



Business Logic Manipulation (Financial Fraud)



Windows Server Service Misconfigurations



Broken Access Control / IDOR Vulnerabilities



Credential Leakage via Unauthenticated APIs



Cross-Site Scripting (Session Hijacking)

ASSESSMENT SCOPE

3 Targets | 8 Services | 1 Web Application

Prepared By: Robes Fokoueng – June 2026

ASSESSMENT SCOPE AND ENVIRONMENT

INTERNAL LAB USE ONLY

TARGET ASSET INVENTORY

ASSET NAME	IP ADDRESS	OS / ROLE	HOSTNAME
Kali Linux	192.168.1.203	Attacker Machine	Attackerhost
Windows Server	192.168.1.219	Server Target (2025)	WIN-C974KSUQ02A
Ubuntu Server	192.168.1.145	Web App Host	Target3
Windows 11	192.168.1.136	Workstation Target	WIN11

NETWORK INFRASTRUCTURE

SUBNET OVERVIEW

192.168.1.0/24

Isolated Home Lab Environment (VirtualBox)

WEB APPLICATION TARGET

OWASP Juice Shop

Node.js | Vulnerable by Design | Port 3000

CONSTRAINTS

Strict Isolation

No internet exposure; zero production impact

SERVICES IN SCOPE FOR ANALYSIS

 SMB (445)

 RDP (3389)

 SSH (22)

 WinRM (5985)

 MSRPC (135)

 NetBIOS (139)

 WSDAPI (5357)

 HTTP (3000)

ASSESSMENT METHODOLOGY

INTERNAL LAB USE ONLY

FRAMEWORK NIST SP 800-115 Technical Guide to Information Security Testing and Examination

01 PLANNING

Define scope: 192.168.1.0/24 subnet

Establish isolated Lab Rules of Engagement

Tool selection: Kali Linux, Nmap, Burp Suite

OBJECTIVES & LOGISTICS

02 RECONNAISSANCE

Passive & active subnet reconnaissance

ARP-based host discovery (nmap -PR)

Technology stack & OS fingerprinting

INFORMATION GATHERING

03 SCANNING

TCP SYN stealth scans with version detection

SMB, RDP, and WinRM service probing

Web application crawling & API discovery

VULNERABILITY IDENTIFICATION

04 EXPLOITATION

SQLi: Authentication bypass & data extraction

IDOR: Basket & API manipulation

Business Logic: Financial fraud validation

ACTIVE EXPLOITATION

05 POST-EXPLOITATION

Admin panel access & hash exfiltration

Lateral movement: SMB relay simulation

Data exfiltration & impact boundary analysis

IMPACT ASSESSMENT

06 REPORTING

CVSS v3.1 severity scoring (2 Critical findings)

MITRE ATT&CK technique mapping

Strategic remediation roadmap

DOCUMENTATION & ROADMAP

ATTACK SURFACE OVERVIEW

INTERNAL LAB USE ONLY

SERVICE	PORT	TARGET HOST	RISK LEVEL
HTTP Juice Shop	3000	Ubuntu Server	CRITICAL
SMB	445	Win Server / WIN11	HIGH
RDP	3389	Windows Server	HIGH
WinRM / WSMAN	5985	Windows Server	HIGH
SSH	22	Ubuntu Server	HIGH
MSRPC	135	Both Windows Hosts	MEDIUM
NetBIOS-SSN	139	Windows Server	MEDIUM
WSDAPI	5357	Windows Server	MEDIUM

PRIMARY ATTACK VECTORS



Web App Exploitation

9 confirmed OWASP Top 10 vulnerabilities including SQLi, IDOR, and XSS.



SMB Relay / NTLM Capture

Lack of signing enforcement on Windows Server allows credential relaying.



SSH Brute-Force

Password-based authentication on Ubuntu enables automated guessing attacks.



Remote Admin Abuse

Exposed RDP and WinRM services provide entry points for lateral movement.

INFRASTRUCTURE SECURITY FINDINGS

INTERNAL LAB USE ONLY

Windows Server 2025

HIGH RISK

192.168.1.219

-  SMB Signing NOT Required: SMB 3.1.1 signing enabled but not enforced, vulnerable to NTLM relay.
-  RDP Exposure (3389): NTLM authentication active without NLA enforcement.
-  WinRM Exposed (5985): HTTP-based management enables RCE if credentials obtained.
-  WSDAPI Exposed (5357): Metadata accessible for internal network reconnaissance.

PRIMARY IMPACT

Lateral movement risk, NTLM credential relay feasibility, and remote administrative abuse potential.

Windows 11

LOW RISK

192.168.1.136

-  SMB Signing: Fully hardened configuration (Enabled and Required).
-  Service Hardening: Minimized attack surface; no legacy protocols active.
-  Secure Baseline: OS configuration aligns with industry hardening standards.

STATUS CONCLUSION

Secure baseline established; no exploitable weaknesses identified during the assessment period.

Ubuntu Server

HIGH RISK

192.168.1.145

-  SSH (22) Password Auth: Vulnerable to automated brute-force attacks.
-  HTTP (3000) Exposed: Juice Shop web application fully accessible.
-  Primary Entry Point: Web services provide high-risk entry for application exploitation.

PRIMARY IMPACT

High likelihood of initial access via web exploitation or credential stuffing against SSH service.

WEB APPLICATION FINDINGS: CRITICAL

INTERNAL LAB USE ONLY

CRITICAL

FINDING F7

SQL Injection: Authentication Bypass

CVSS V3.1 SCORE

9.8

MITRE ATT&CK

T1190

Classic SQLi vulnerability identified in the login email field.
Allows bypassing all authentication logic to gain administrative access without valid credentials.

Payload: ' OR 1=1--

Evidence: Admin panel fully accessible; all user accounts and security logs exposed.

BUSINESS IMPACT

Full compromise of the authentication system, unauthorized global admin access, and total loss of data integrity.

CRITICAL

FINDING F8

SQL Injection: Search Functionality

CVSS V3.1 SCORE

9.1

MITRE ATT&CK

T1190

User-controlled search input is unsanitized, enabling full database query manipulation.
Error-based injection allows mapping the entire backend database structure.
Exposed tables: Users, Products, Baskets, Orders, and Payment Details.
Facilitates targeted data exfiltration of PII and financial records.

BUSINESS IMPACT

Complete database schema exposure and potential for mass data exfiltration of sensitive organizational information.

WEB APPLICATION FINDINGS: HIGH & MEDIUM

INTERNAL LAB USE ONLY

ID	SEVERITY	VULNERABILITY DESCRIPTION	CVSS
F1	HIGH	Feedback Access Control Weakness	8.1
F2	HIGH	Sensitive Data Exposure — User Hash Leak via /rest/memories	8.6
F4	HIGH	IDOR — Basket API Manipulation	8.1
F5	HIGH	Business Logic: Negative Quantity Wallet Abuse	7.5
F6	HIGH	Confidential File Exposure — /ftp/acquisition Access	7.8
F9	HIGH	XSS — Persistent/Reflected Search Script Execution	7.4
F3	MEDIUM	API Overexposure — /api/quantity Leak	4.3

F2/F4: API & Data Exposure

Exposure of bcrypt password hashes and unauthenticated access to user shopping baskets. Enables offline cracking and PII theft.

[illegible]

EVIDENCE: BASKET API RESPONSE LEAK

F5/F1: Logic & Access Control

Negative quantity injection generates fraudulent credits.
Feedback API allows unauthorized modification of site content.

```

1 Host: 192.168.1.145:3000
2
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: application/json, text/plain, */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/json
8 Content-Length: 84
9 Origin: https://192.168.1.145:3000/
10 Connection: keep-alive
11 Referer: https://192.168.1.145:3000/
12 Cookie: language=contuneCodeFudgeyviNv8nVh13m28v8G2v9v1LcN04G1d4eXKXpJ16z70w4k825e;
    welcomeBanner_status=dismiss
13 Priority: u=0
14
15 {
16   "captchaId":6,
17   "captcha": "1UP",
18   "comment": "I like this job (Pentester)",
19   "rating":305
20 }
21
22 Access-Control-Allow-Origin: *
23 X-Content-Type-Options: nosniff
24 X-Frame-Options: SAMEORIGIN
25 Feature-Policy: payment 'self'
26 X-Recruiting: #/jobs
27 Location: /api/Feedbacks/52
28 Content-Type: application/json; charset=utf-8
29 Content-Length: 182
30 ETAG: W/"16b-H5vQvGd9r1TEN G5u0F8b0Bjy""
31 Vary: Accept-Encoding
32 Date: Tue, 20 May 2026 21:15:17 GMT
33 Connection: keep-alive
34 Keep-Alive: timeout=5
35
36 {
37   "status": "success",
38   "data": {
39     "id":52,
40     "comment": "I like this job (Pentester)",
41     "rating":305,
42     "updatedAt": "2026-05-20T21:15:17.223Z",
43     "createdAt": "2026-05-20T21:15:17.223Z",
44     "user": null
45   }
46 }

```

EVIDENCE: UNAUTHORIZED FEEDBACK API POST

CROSS-SYSTEM RISK ANALYSIS: CHAINED ATTACK SCENARIOS

INTERNAL LAB USE ONLY

1

WEB-TO-FULL-DATABASE COMPROMISE

CATASTROPHIC

SQLi Auth Bypass (9.8) > Admin Session Takeover > SQLi Search Enumeration

 **Impact:** All user PII, password hashes, and financial records exfiltrated.

2

SMB RELAY → LATERAL MOVEMENT

CRITICAL

SMB Signing Disabled > NTLM Challenge Capture > Relay to WinRM (5985)

 **Impact:** Unauthenticated Remote Command Execution (RCE) on Windows Server 2025.

3

CREDENTIAL HARVEST → SYSTEM PIVOT

HIGH

API Memory Leak (8.6) > Offline Hash Cracking > SSH/RDP Credential Stuffing

 **Impact:** Cross-system account takeover targeting Ubuntu and Windows infrastructure.

4

XSS → SESSION HIJACK → FRAUD

HIGH

XSS Search Payload > Session Token Theft > Negative Qty Logic Abuse

 **Impact:** Unauthorized account control and fraudulent wallet credit generation.

CHAINED SEVERITY

Critical / Catastrophic

PRIMARY ENTRY

SQLi / SMB Relay

MITRE MAPPING

T1190 / T1557.001

REMEDiation URGENCY

IMMEDIATE (0-48h)

RISK SUMMARY DASHBOARD

INTERNAL LAB USE ONLY

TOTAL FINDINGS	CRITICAL FINDINGS	AVG. CVSS SCORE	INFRASTRUCTURE RISK
13	2	7.8	High

ID	SECURITY FINDING	CATEGORY	SEVERITY	CVSS V3.1	MITRE ATT&CK
F7	SQL Injection — Authentication Bypass	Web App	CRITICAL	9.8	T1190
F8	SQL Injection — Search Functionality	Web App	CRITICAL	9.1	T1190
F2	Sensitive Data Exposure (/rest/memories)	Web App	HIGH	8.6	T1213
F1	Feedback Access Control Weakness	Web App	HIGH	8.1	T1190, T1548
F4	IDOR — Basket API Manipulation	Web App	HIGH	8.1	T1021
INF	SMB Signing Not Required (WIN Server)	Infra	HIGH	—	T1557.001
F6	Confidential File Exposure (/ftp)	Web App	HIGH	7.8	T1081
F5	Business Logic: Negative Quantity Abuse	Web App	HIGH	7.5	T1548
INF	RDP NTLM Exposure	Infra	HIGH	—	T1021.001
INF	WinRM Exposed via HTTP (5985)	Infra	HIGH	—	T1021.006
F9	XSS — Persistent Search Functionality	Web App	HIGH	7.4	T1059.007
F3	API Overexposure (/api/quantity)	Web App	MEDIUM	4.3	—
INF	WSDAPI Exposed Service (5357)	Infra	MEDIUM	—	—

OVERALL BUSINESS IMPACT

INTERNAL LAB USE ONLY



AUTHENTICATION COMPROMISE

SQL injection login bypass grants administrative access to any user account without valid credentials, nullifying core security controls.



CREDENTIAL HARVESTING

API exposure of bcrypt password hashes facilitates offline cracking, leading to broader account compromise across the enterprise.



MASS DATA EXFILTRATION

Unsanitized search functions enable full extraction of PII, order history, and financial records from the backend database.



LATERAL MOVEMENT PIVOT

SMB relay and WinRM exposures allow attackers to pivot from web application breaches to full Windows Server infrastructure control.



FINANCIAL FRAUD RISK

Business logic flaws in order quantities allow generation of fraudulent wallet credits and negative-price transactions.



REGULATORY VIOLATIONS

Unauthorized exposure of PII and credential data violates GDPR and industry-specific data protection requirements, risking heavy fines.



ACCOUNT TAKEOVER AT SCALE

Chained IDOR and XSS vulnerabilities allow attackers to hijack active user sessions and modify account data without interaction.



REPUTATIONAL DAMAGE

Persistent XSS enables internal phishing campaigns that erode user trust and compromise the integrity of the digital brand.

OVERALL ASSESSMENT

The environment presents a **multi-layered, chained attack surface**. A single exploitation entry point (e.g., SQLi) could cascade into **complete environment compromise** across both web and infrastructure layers in a production setting.

STRATEGIC RECOMMENDATIONS:

INTERNAL LAB USE ONLY

⚡ IMMEDIATE

0 – 48 Hours

Eliminate SQL Injection

CVSS 9.8

Migrate to parameterized queries; deploy WAF rules for immediate protection.

Secure Authentication

CRITICAL

Implement MFA; rotate all compromised credentials; harden login endpoints.

API Data Sanitization

CVSS 8.6

Audit /rest/memories and strip sensitive credential hashes from API returns.

CORE OBJECTIVE

Sever critical exploit paths and stop active data exfiltration vectors.

🛡️ HIGH PRIORITY

Next 14 Days

Implement RBAC / ABAC

CVSS 8.1

Enforce authorization checks on all object-level references (IDOR fix).

Logic & Validation Fixes

CVSS 7.5

Enforce server-side validation for quantities and financial values.

XSS Defense-in-Depth

CVSS 7.4

Deploy CSP headers and implement context-aware output encoding.

Restrict File Access

CVSS 7.8

Lock down /ftp/ directory; require authentication for document retrieval.

CORE OBJECTIVE

Harden application logic and prevent unauthorized access to sensitive objects.

⚙️ HARDENING

Next 30 Days

Enforce SMB Signing

INFRA

Require security signatures for SMB 3.1.1 to neutralize NTLM relay attacks.

Secure Remote Access

INFRA

Enable NLA for RDP; enforce HTTPS and IP allowlisting for WinRM.

Harden SSH Auth

INFRA

Disable password authentication; enforce SSH key-pairs exclusively.

Reduce Attack Surface

LOW

Disable WSDAPI (5357) and NetBIOS (139) on all Windows hosts.

CORE OBJECTIVE

Block lateral movement and eliminate unauthenticated remote management vectors.

CONCLUSION AND KEY TAKEAWAYS

INTERNAL LAB USE ONLY

FINAL RISK POSTURE



The June 2026 assessment confirms that the environment remains highly vulnerable to systemic compromise. The presence of critical SQLi vulnerabilities acts as a primary catalyst for wider environmental breach.

2

CRITICAL FINDINGS

6

HIGH SEVERITY

13

TOTAL ISSUES

Security is only as strong as its weakest link; in this lab, the web application is the open gate to the entire infrastructure.



Systemic Chain Attack Risks

The primary threat is not individual bugs, but the ability to chain web exploits (SQLi/XSS) with network misconfigurations (SMB Relay) to achieve full DC control.



Holistic Remediation Necessity

Patching the web layer alone is insufficient. Holistic defense requires simultaneous hardening of the API authorization logic and infrastructure service signing protocols.



Authentication & Data Integrity

Complete loss of trust in the authentication system was demonstrated. Migration to parameterized queries and multi-factor authentication is the highest priority.



Infrastructure Hygiene

Windows Server 2025 and Ubuntu assets require immediate service reduction. Disabling unused ports (WSDAPI, NetBIOS) significantly reduces the internal reconnaissance surface.